

Portable Approval State Does Not Convey the Approver-Eligibility Basis

An independent analysis of the AuthZEN Access Request and Approval Profile, Draft 1

Margaret Stokes

Independent researcher and AI architect

ORCID: 0009-0004-6422-4174

DOI: 10.5281/zenodo.21738810

1 August 2026 | Version 1.0

STATUS OF THIS NOTE

This document is an independent analysis of the publicly available AuthZEN Access Request and Approval Profile - Draft 1, published 27 July 2026. It has not been submitted to the OpenID Foundation or the AuthZEN Working Group for consideration, inclusion, or adoption as specification text.

Abstract

The AuthZEN Access Request and Approval Profile requires an Access Request Service to evaluate approver eligibility before returning an approved result. In the profile's portable bound-reference topology, however, the Policy Decision Point can verify the issuer, integrity, scope, status, and lifetime of an approval without being able to determine whether the required eligibility evaluation occurred, which policy governed it, or whether an exception was applied. This note identifies the resulting verification boundary, distinguishes integrity-protected assertion from evidence of procedural compliance, and examines its consequences for inline authorization and retrospective audit.

DOCUMENT ANALYSED

Sections 12, 18, and 21.2.2; Appendix B.5; and Appendices C.3, C.5, and C.8 of AuthZEN ARAP Draft 1 [1].

1. Summary

Section 21.2.2 requires the Access Request Service to evaluate approver eligibility before returning approved, including self-approval restrictions, delegated authority, separation-of-duties constraints, ownership rules, and conflict-of-interest policy. Section 18 repeats this as a processing requirement.

Section 12 does not require the portable approval record or its verifiable binding material to identify the evaluator, identify the eligibility policy applied, or indicate whether the required evaluation succeeded or was overridden under the exception permitted by Section 21.2.2.

Consequently, a Policy Decision Point (PDP) using the bound-reference pattern can verify that the Access Request Service issued an approval and that the approval is bound to the relevant request. It cannot determine from the portable approval whether the eligibility requirement was satisfied.

2. Bound-reference topology

In the lookup pattern, a PDP may obtain additional workflow information from shared trusted state.

In the bound-reference pattern, the PDP verifies an integrity-protected `approval.state`. Section 12 requires that the approval record or verifiable material contain, or allow the PDP to determine:

- the approval and task identifiers;
- the original denied evaluation identifier, when available;
- the approved Subject, Resource, Action, context, or scope;
- requester and client binding;
- approval status and lifetime; and
- revocation or cancellation state.

The required material does not include:

- the human or automated evaluator responsible for the approval;
- the eligibility policy or policy version applied;
- the result of the eligibility evaluation; or
- whether an ineligible evaluator was accepted under the local-policy exception in Section 21.2.2.

A conforming eligibility evaluation and an omitted, failed, or excepted evaluation are therefore indistinguishable to the PDP with respect to the portable approval material.

Appendices C.3, C.5, and C.8 expose an asymmetric verification design. In the denial direction, an independent Access Request Service need not accept the PEP's assertion that a denial occurred: the denial can be cryptographically bound by the PDP. In the approval direction, an integrity-protected `approval.state` allows the PDP to authenticate the approval assertion and its binding without shared state. The protected material nevertheless does not represent the eligibility basis from which the approval derives.

The PDP can verify who made the assertion and what it applies to. It cannot verify from the portable state whether the process required to authorize that assertion was performed.

3. The verification boundary

An integrity-protected approval establishes that the identified issuer made the assertion and that the protected claims have not been altered. It does not independently establish that the issuer performed the workflow required by Section 21.2.2.

This may be an intentional allocation of responsibility to the Access Request Service. If so, the trust boundary remains important: `approval.state` should not be read as PDP-verifiable evidence of approver eligibility merely because it is verifiable as an issued and unaltered approval assertion.

The same omission limits reconstruction under Section 18. The service must retain sufficient audit records, but the specification does not state whether reconstructing 'the approval' includes the evaluator, eligibility decision, applicable policy, and any exception.

4. Architectural consequences

1. Clarifying the trust boundary. The profile could state that approver eligibility is evaluated exclusively by the Access Request Service and lies outside the PDP's verification obligations. Verification of `approval.state` would then be understood to establish issuer authenticity, integrity, binding, status, and lifetime without establishing workflow compliance.
2. Supporting retrospective audit. Retained audit records, and optionally portable approval state, could include a deployment-defined `evaluator_ref`, the applicable eligibility-policy reference or version, the eligibility result, and any exception or override. This would improve reconstruction and attribution without making the PDP responsible for repeating the eligibility evaluation.
3. Supporting PDP-verifiable eligibility. An optional profile could carry sufficient integrity-protected eligibility evidence for the PDP to evaluate or verify under a known policy. A signed assertion that an eligibility check occurred improves attribution and auditability, but does not by itself establish that the check was performed correctly.

The first direction resolves the ambiguity with minimal protocol change. The second improves accountability and reconstruction. The third is required if portable, inline PDP verification is an intended property.

5. Conclusion

ARAP Draft 1 creates a portable approval object that can be authenticated, bound, time-limited, and checked for current applicability. Those are substantial properties. Approver eligibility occupies a different evidentiary category: it concerns whether the authority asserted by the approval was produced through an admissible process.

The current portable state does not convey that basis. The specification can therefore treat eligibility as delegated trust, portable audit evidence, or a PDP-verifiable condition, but those choices should remain distinguishable. Integrity protects an assertion against alteration. It does not supply the missing evidence of how the asserted authority came to stand.

References

- [1] K. McGuinness, AuthZEN Access Request and Approval Profile - Draft 1, OpenID AuthZEN Working Group, published 27 July 2026, accessed 1 August 2026.
https://openid.github.io/authzen/authzen-access-request-approval-profile-1_0.html